

Vendor Response Template - RFI

Structured response document for suppliers responding to the LatticePay Request for information on ISO/IEC 42001:2023 advisory, implementation, readiness, and certification support.

Procurement reference	LTP-RFI-42001-RESP
Company	LatticePay Financial Technologies, Inc.
Standard	ISO/IEC 42001: 2023 Artificial Intelligence - Management system

****Note:** This RFI response is for a fictional company as part of a portfolio to demonstrate competence and understanding of the RFI/RFP response cycle. Both LatticePay and Asterion are fictional companies used for the purpose of this exercise.

How to use this template

This document can be completed in lieu of a free-form narrative wherever practical. You may add rows or appendices if needed, but keep the numbering and section order intact. Reference attachments clearly in the last column or in the relevant section so the evaluation team can trace supporting evidence quickly. Replace any bracketed or placeholder text throughout before submission.

1. Respondent information

Vendor legal entity	Asterion Certification Services, Ltd.
Primary contact name and title	Rani Cyber, Vice President, Financial Services Certification
Email and phone	Rani.cyber@Asterioncert.com +1-123-456-7890
Headquarters Location	Niagara Falls, Ontario, Canada
Date submitted	April 5 2026
Website	www.Asterioncert.com

2. Executive summary

Provide a concise overview of your firm and why it is well suited to support LatticePay

Address ISO/IEC 42001 capability, fintech relevance, delivery model, and differentiators in approximately one page

Asterion Certification Services, Ltd. (Asterion) is a financial-services-focused certification body that specializes in independent readiness reviews and accredited management-system certification for organizations deploying material AI in regulated environments. We are a strong fit for LatticePay because our teams combine ISO/IEC 42001, ISO/IEC 27001, ISO 27701, payment risk, cloud control testing, and model-governance expertise, with a delivery approach built around fast evidence mobilization and clear certification decision criteria. For clients in scope for certification by Asterion, our role is intentionally independent: we do not author policies, operate controls, or act as management. Instead, we perform gap diagnostics, pre-assessments, document reviews, auditor-style interviews, and Stage 1/ Stage 2 certification activities that help clients know exactly what evidence is required to achieve a certifiable AI management system. This preserves impartiality while giving LatticePay a practical, low-friction path to certification

3. Core RFI response matrix

#	Question/Topic	Suggested response length	Vendor response/attachment reference
1	Describe your experience standing up a certifiable AI management system, including the number and type of ISO/IEC 42001 engagements completed or underway	1-2 pages	Asterion does not consult on the design of an AI management system for clients we may later certify; however, during the last 24 months we have assessed certifiability across 41 AI-intensive organizations, including 14 in financial services, payments, lending, or adjacent regulated sectors. Our work has included

			pre-assessments, readiness reviews, stage 1 audits, stage 2 audits, and corrective-action verification for organizations operating customer-facing decisioning, fraud, AML, underwriting, support automation, and internal productivity AI. From those engagements, we have developed a strong view of the operating evidence that separates well-designed AIMS programs from paper-only implementations. Typical strengths in successful programs include clearly bounded scope, an accurate AI system inventory, decision-rights between product and risk teams, repeatable risk assessment criteria, supplier oversight for this-party models, monitoring for model drift and harmful outcomes, and management review inputs tied to real metrics. Attachment reference: Section 6
2	Explain how you scope AI systems, functions, and business units for ISO/IEC 42001 in mixed environments that include internal models and third-party AI-enabled services	1 page	In mixed environments, we begin with business purpose and accountability rather than technology labels. We ask LatticePay to identify which products, workflows, and internal functions materially rely on AI outputs, then map those uses to process

RFI Response Template

			owners, legal entities, customer journeys, data domains, and supporting third parties. Scope is then structured around a certifiable boundary: included AI use cases, shared control functions, excluded activities, and interfaces that must still be governed. For fintech clients, we pay particular attention to third-party foundation models, fraud tooling, customer support copilots, model risk functions, and manual override controls. The end state is a scope statement plus inventory and interface map that show which teams own risk assessment monitoring, incident response, supplier management, and management review evidence.
3	Summarize the mandatory documents, records, and operating evidence you typically help clients establish to support a certifiable AIMS	1 page	From an assessor perspective, the mandatory evidence set normally includes: a defined AIMS scope; AI policy and objectives; roles and responsibilities; an inventory of material AI use cases and suppliers; criteria for risk assessment and treatment; records of performed assessments and approved treatment plans; operational procedures for data governance, testing, release, human

RFI Response Template

			oversight, incident response, monitoring, and change management; competence and awareness records; internal audit and management review outputs; nonconformity and corrective action records; and a documented control applicability matrix aligned to the organization's chosen controls. We also expect traceable evidence that these documents are used in practice, for example approvals, exception logs, review cadence, KPIs, sampled decisions, monitoring outputs, and supplier due-diligence records.
4	Describe your approach to AI risk assessment, treatment planning, control design, and evidence collection in regulated or high-trust environments	1 page	At Asterion , our approach is risk-based and evidence-led. We expect regulated organizations to connect AI-specific risk assessment to enterprise risk, information security, privacy, model risk, consumer protection, legal, and operational resilience processes. We look for a defined taxonomy covering harm to individuals, unfair outcomes, explainability limits, robustness failures, misuse, security threats, data quality issues, regulatory non-compliance, and

RFI Response Template

			vendor concentration. We then test whether treatment plans are specific, owned, time-bound, and reflected in operational controls. Evidence collection focuses on what an auditor can verify: documented criteria, completed assessments, approvals, sampled monitoring reports, incident records, overrides, exception handling, and management action. For fintech clients, we also test how AI governance interacts with change control, compliance sign-off, and customer complaint escalation.
5	Explain how you address responsible AI, model governance, privacy, security, legal, and compliance dependencies without creating duplicate process layers	1 page	We evaluate responsible AI as a cross-functional management system rather than a standalone ethics program. Strong respondents define a single governance forum with clear escalation thresholds, while preserving names accountability across product, engineering, model risk, security, privacy, legal and compliance. In practice, we expect one owner for the AIMS, one owner for each material AI use case, and clear evidence requirements for supporting functions. This avoids diffusion of accountability. We also expect a common risk

RFI Response Template

			language so fairness, human oversight, privacy, security, and legal obligations are addressed through one decision workflow instead of parallel committees. Where external models or vendors are involved, we look for supplier-specific controls and contract evidence showing how LatticePay retains oversight of outputs that affect customers, employees, or regulated decisions.
6	Provide representative fintech, banking, payments, or similarly regulated case studies and summarize outcomes achieved	1-2 pages	Representative comparable work includes: (1) a global payments processor using machine-learning fraud controls and support automation, where we performed a pre-assessment and then Stage1/ Stage 2 certification path review across product, security, and operations functions; (2) a digital consumer lender with AI-assisted underwriting and collections analytics, where our readiness review identified missing oversight for third-party models and weak management review inputs, enabling remediation before formal audit; and (3) a banking-as-a-service platform using internal copilots and risk-scoring analytics, where we

RFI Response Template

			assessed scope boundaries, supplier governance, and evidence sufficiency for a multi-team AIMs. In each case, success depended on practical governance, strong evidence mapping, and early closure of independence-sensitive activities.
7	Describe how you support internal audit readiness, mock assessments, and preparation for Stage 1 and Stage 2 certification audits	1 page	Our support model is appropriate for a certification body: we provide pre-assessment workshops, document reviews against requirements, evidence sampling, interview preparation, readiness reporting, stage 1 planning, stage 1 audit, stage 2 audit, and corrective-action verification. We can also facilitate auditor-style mock interviews and provide examples of the level of objective evidence required, but we do not write client procedures, operate controls, or serve as the internal auditor of record for organizations we certify. For LatticePay, we would recommend a fast-track sequence of scope confirmations, pre-assessment, targeted evidence maturation, stage 1, remediation, and stage 2, with a single program lead maintaining decision logs and closure tracking.

RFI Response Template

8	Disclose any relationships with certification bodies or affiliated audit entities and explain how independence and impartiality would be maintained.		Asterion is itself the proposed certification body. We do not provide implementation consulting to clients on the same scoped management system we intend to certify, and we do not rely on an affiliated consulting entity for back-door delivery. Independence is preserved through separate commercial, audit, technical review, and certification-decision functions; auditor rotation rules' a conflict screen at contract acceptance; and a certification decision committee that does not report to the delivery team. If LatticePay wishes to engage a separate consultant for policy drafting, control design, or internal audit execution, that provider must remain independent of Asterion's certification decision process.
9	Outline your preferred engagement model, expected team composition, delivery cadence, and indicative timeline for a typical end-to-end program		Our preferred delivery model is hybrid and milestone-based. For a fintech organization of LatticePay's apparent complexity, we would expect a 10-14 week path from kickoff to stage 2 readiness, assuming an executive sponsor is named, the AI inventory is mostly known, and baseline controls already exist across security, privacy,

RFI Response Template

			change management, and incident response. A typical cadence is: week 1 kickoff and scope workshop; week 2-3 pre-assessment and document review; weeks 4-7 remediation sprints owned by the client; weeks 8 readiness checkpoint; weeks 9-10 stage 1 audit; weeks 11-14 closure and stage 2 audit. Timing compresses or expands primarily based on documentation maturity and the number of in-scope AI use cases.
10	Describe your pricing approach, including any common commercial structures, major cost drivers, and assumptions		We usually price in fixed-fee stages so the client can align spend to decision points: preassessment, stage 1, stage 2, and corrective-action review. Major cost drivers are scope breadth, number of legal entities and locations, count and criticality of AI use cases, reliance on third-party models, expected sample sizes, and whether documentation is already in near-audit form. We can also price optional workshops or surveillance years separately. For LatticePay, we would likely recommend a bundled fixed-fee readiness-and-certification package with capped travel, limited out-of-scope change

			orders, and explicit assumptions around document language, availability of process owners, and corrective-action turnaround.
--	--	--	--

4. Delivery model and team profile

Role/ Capability area	Named person or proposed profile	Relevant qualifications and experience	Location/delivery model
Executive sponsor	Daniel Mercer, managing director - North America	22 years in accredited management-system certification; former banking assurance partner; executive sponsor for regulated-sector accounts.	New York Executive oversight, remote + onsite as needed
Engagement lead/project manager	Rani Cyber, VP Financial Services Certification	Lead for fintech engagements; ISO/IEC 42001 and ISO/IEC 27001 lead auditor; 17 years in payments and assurance delivery	*was New York* Niagara Falls Hybrid program leadership
ISO/IEC 42001 subject matter lead	Dr. Ravi Nandakumar, Global ISO/IEC 42001 Practice Lead	PhD in machine learning; former bank model-risk executive; deep experience in AI inventory, control evidence, and auditability.	London remote with planned onsite workshops
AI governance/risk specialist	Claire DuBois, Principal AI Governance Assessor	Specialist in AI risk, privacy, supplier oversight, and regulated decisioning;	Toronto remote/periodic onsite

		background in card payments and digital lending.	
Internal audit or readiness reviewer	Elena Brooks, Director, Assurance Quality & Independence	CISA, ISO lead auditor, and quality reviewer responsible for readiness challenge and independence controls.	Chicago remote quality review
Other Key contributors	Security assessor, payments SME, and client success coordinator	Bench support for cloud controls, evidence management, and audit logistics, staffed based on final scope	US/UK blended delivery

5. Indicative commercial structure

Commercial element	Response
Preferred pricing model	Fixed fee by stage, with milestone billing tied to pre-assessment, stage 1, stage 2, and corrective-action review.
Indicative project range	USD 285,000-340,000 for pre-assessment, stage 1, stage 2, and one corrective-action review cycle; annual surveillance typically USD 60,000-85,000
Assumptions affecting price	Assumes one primary legal entity, English-language materials, up to 25 material AI use cases, and client-owned remediation between readiness checkpoints
Travel and expenses treatment	Travel billed at cost and capped by prior written approval; remote-first delivery is assumed for document review and selected interviews.
Third-party tools or licenses expected	No proprietary platform required. We can work in LatticePay collaboration tools and provide evidence trackers in standard office formats.

6. References and evidence

Client/organization type	Scope summary	Outcome achieved	Reference availability
Global payments processor (anonymized)	Enterprise AIMS spanning fraud analytics, support automation, and shared security/compliance functions across North America and Europe.	Completed readiness review and certification audit path with only minor stage 1 documentation observations	Reference available under NDA after shortlist.
Digital consumer lender (anonymized)	AI-assisted underwriting, collections analytics, and this-party model dependencies in a highly regulated operating model.	Identified and closed supplier-governance and management review gaps before formal audit, reducing certification delay risk.	Reference available under NDA after shortlist.
Banking-as-a-service platform (anonymized)	Internal copilots, risk-scoring analytics, and cloud-native controls across engineering, operations, and compliance	Supported scope definition, pre-assessment, and evidence maturation resulting in an audit-ready AIMS within one quarter	Reference summary available now; live call after shortlist.

7. Assumptions, constraints, and exceptions

List any assumptions, exclusions, dependencies, or qualifications that LatticePay should understand when reviewing your RFI response.

Also note any areas where additional information would materially affect your indicative timeline or pricing view.

Our indicative view assumes LatticePay will retain ownership of policy drafting, control implementation, management review, and internal audit execution. Asterion's role is limited to independent readiness review and certification activities appropriate for a certification body. Pricing and timing assume English-language documentation, timely access to named process wonders, a mostly complete AI use-case inventory at kickoff, and no material scope expansion after Stage 1 planning.

If LatticePay chooses to outsource implementation or internal audit to another provider, that provider must remain independent of Asterion's certification decision process for the same scope.

8. Submission checklist.

Item	Included	Notes
Executive summary completed	Yes	Sections 2-9 complete
Core response matrix completed	Yes	Section 3 completed in full
Delivery team information included	Yes	Section 4 completed with named leads
Indicative commercial approach included	Yes	Section 5 includes indicative commercial range
References or case studies attached	Yes	Section 6 includes anonymized comparable engagements
Independence/conflict disclosures included	Yes	Section 7 and Question 8 disclose independence model

9. Respondent certification

Authorized signatory name	Daniel Mercer
Title	Managing Director - North America
Signature	s/ Daniel Mercer (electronic signature)
Date	April 5th, 2026